

Control interno y seguridad informática

El Concepto de control interno **no** se incluía dentro de las diversas operaciones / actividades operativas de la empresa. Debido a las grandes quiebras las empresas han comenzado a tomar conciencia de la necesidad de contar con **controles internos efectivos** para evitar que surjan o se promuevan los **fraudes**.

En la actualidad, muchos de los controles son incorporados en los programas informáticos o en su infraestructura relacionada, siendo esta tarea realizada por el grupo de **control interno informático** o comúnmente llamado **seguridad informática**.

Sus principales objetivos son:

- Controlar que todas las actividades se realizan según los procedimientos fijados y las reglamentaciones vigentes.
- Asesorar en el conocimiento de normas internas y externas.
- Colaborar / entregar información a auditorías.
- Definir, implantar y ejecutar mecanismos y controles para comprobar el logro de los niveles adecuados de servicio. Tener en cuenta que no es el único responsable...cada dueño debe velar por el aseguramiento de su trabajo.
- Realizar sobre los distintos sistemas el control de las actividades operativas (independientemente el entorno):
 - Cumplimiento de procedimientos.
 - Control de la producción diaria.
 - Control de calidad y eficiencia en desarrollo.
 - Controles sobre redes, software de base, sistemas microinformáticos.
 - Seguimiento de relaciones contractuales y cumplimientos jurídico.
 - Protección de datos.
- Asesorar sobre riesgos informáticos.

Otras funciones pueden ser:

- Clasificación de activos de información / inventario de activos.
- Desarrollo y actualización del plan de contingencia de sistemas.
- Plan de seguridad de la información.
- Definir procedimientos de control en desarrollo (pasajes a producción).

- Definir medidas de seguridad física.
- Realizar el monitoreo de las redes corporativas.

Similitudes con la Auditoría Informática

- Personal con conocimiento especializado en TI.
- Verifican el cumplimiento de los controles, normativas y procedimientos.
- Por lo general se trata de personal interno de la empresa.

Diferencias con la Auditoría Informática

Control Interno Informático	Auditoría Informática
Análisis de controles en el día a día	Análisis de Controles en momentos Determinados
Generalmente informa al Gerente de Sistemas	Generalmente informa a la dirección de la Empresa
Generalmente el Alcance de sus tareas es el área de sistemas	Tiene cobertura sobre todos los componentes de los sistemas de información de la organización

Sistema de Control Interno Informático (CII)

Un sistema de CII puede definirse como:

“Cualquier actividad realizada manual o automáticamente para prevenir, corregir errores o irregularidades que puedan afectar al funcionamiento de un sistema para conseguir sus objetivos asegurando: Confidencialidad, Integridad, disponibilidad” (Mario Piattini y Emilio del Paso).

Características:

- Completos.
- Simples.
- Revisables /medibles.
- Adecuados.
- Rentables -> costo / riesgo de implementación.

Implementación de un Sistema de Control Interno

Básicamente habrá que definir:

- Gestión de Sistemas de Información: definición de políticas, normas, procedimientos y estándares técnicos que sirvan de base para el diseño y la implementación de los sistemas de información.
- Administración de sistemas: controles sobre la actividad de los centros de datos y sus funciones de apoyo.
- Seguridad: controles sobre CIA.
- Gestión del Cambio: separación de entornos, procedimientos definidos para la migración de programas.

Controles aplicables a las distintas áreas de Sistemas

Controles generales en el área de Sistemas

- Documentación de planificación: plan estratégico de sistemas, define como Sistemas cubre las necesidades del negocio. Por ejemplo: plan estratégico de SI, garantía de CIA, plan de recuperación ante desastres.
- Estándares: adquisición de software, diseño y desarrollo de software, explotación de sistemas, etc.
- Procedimientos: por ejemplo definición de roles y responsabilidades el área de Sistemas, políticas del personal: formación, evaluación, etc.
- Organización de TI: garantizando independencia del área usuaria.
- Revisión de informes de control.
- Política de clasificación de información.

Controles en el desarrollo, adquisición y mantenimiento de sistemas

Buscando alcanzar: Eficacia -> Alcanzar los objetivos; Eficiencia -> Alcanzar los objetivos con mínimo uso de recursos (Economía), integridad de datos, cumplimiento de leyes y regulaciones.

Metodología de ciclo de vida

- Publicación interna de la metodología.
- Responsabilidad de los equipos de proyecto (sistemas y usuarios finales).
- Definición de especificaciones para nuevos desarrollos.
- Estudio de factibilidad (análisis de costo / beneficio).
- Metodología de gestión de proyectos.

- Procedimientos de documentación de especificaciones: diseño, entrada/salida, procesos, controles de seguridad, pistas de auditoría, etc.
- Plan de pruebas o verificación formal
- Procedimientos de adquisición de software / contratación de servicios tercerizados: mesa de ayuda, programación, etc.

Explotación y mantenimiento

- En este aspecto se busca la integridad de los datos y que su modificación se realice mediante accesos adecuados.
- Procedimientos de control de explotación.
- Procedimientos de control y seguimiento de cambios para un sistema.

Controles de explotación de un Sistema de Información

Planificación y gestión de recursos:

- Presupuesto operativo.
- Gestión de la capacidad.
- Adquisición de equipos.
- Carga de trabajo.
- Programación del personal.
- Mantenimiento preventivo.
- Gestión de problemas.
- Facturación de servicios a usuarios.
- Gestión de librerías de datos.

Aspectos vinculados a la selección del software

- Instalación.
- Mantenimiento.
- Control de cambios.

Seguridad física y lógica:

- Armado del grupo y definición de funciones.
- Gestión de los sistemas vinculados.
- Medidas de protección física.
- Procedimientos de concientización en temas de seguridad.
- Mecanismos de control de accesos.

- Plan de continuidad.

Controles en aplicaciones

- Deben garantizarse las entradas, el procesamiento (actualizaciones) y las salidas.
- Procedimientos de control de tratamiento: por ejemplo conversión de datos, validación y corrección.
- Procedimientos de tratamiento: asegurar que no se dan de alta, modifican datos de manera no autorizada.
- Procedimientos de salida: procedimientos de consolidación de salidas, gestión de errores de salida.

Controles de tecnologías

Bases de datos:

- Integridad referencial.
- Definición de roles.
- Controles sobre los accesos y concurrencia.
- Descripción de cambios.
- *Backups*, recuperación.
- Integridad de los datos.

Seguridad Informática

Objetivo de la función

Lograr una adecuada protección de la información y control de los accesos en el procesamiento de datos y en los sistemas de información, con la finalidad de preservar la integridad, disponibilidad y confidencialidad de la misma.

Alcance

La función de Seguridad Informática encargará de la administración, control y supervisión de todos los aspectos relacionados con la seguridad de la información.

Asimismo, participará con otras áreas en cubrir aspectos que, sin ser competencia suya, indirectamente puedan afectar a la seguridad de la información.

Por otra parte, diseñará las normas y circuitos organizativos destinados a alcanzar un adecuado acceso a la información, manteniendo la integridad, disponibilidad y confidencialidad de la misma.

Referencias bibliográficas

- Piattini, M. y Del Paso, E. *Auditoria Informática: Un enfoque práctico* (Capítulo 2: “Control Interno y Auditoría Informática” y Capítulo 3: “Metodología de Control Interno, Seguridad y Auditoría”).